

Unifolio — Privacy Policy

Effective date: 2026-05-13

Last reviewed: 2026-05-13

Operator: Unifolio Inc. ("Unifolio", "we", "us", "our") — a federally incorporated Canadian company.

Contact: privacy@unifolio.ca (monitored by the CEO; replies within 5 business days).

This policy explains what personal information Unifolio collects, why we collect it, how we store and protect it, and your rights to access, correct, or delete it. It applies to all use of unifolio.ca, unifolio.pro, and any associated mobile or desktop apps.

This policy complies with Canada's **Personal Information Protection and Electronic Documents Act (PIPEDA)**, the **GDPR** for users in the EU/UK, and applicable provincial privacy laws including Quebec's **Law 25**.

1. What we collect

1.1 Account information (provided by you)

- Email address (required for sign-up)
- Display name and optional profile photo
- Password (hashed by Supabase Auth; we never see or store your plaintext password)
- Optional profile fields you choose to enter: phone number, location, biography
- Communication preferences (email-alert toggle, etc.)

1.2 Financial data (provided by you, directly or through Plaid)

- **Imported broker statements** (CSV, IBKR Flex Query, Wealthsimple activity exports, etc.) — including account names, holding positions, transactions, dividends, realized gains.
- **Plaid-connected account data** (when you authorize Plaid Link) — account balances, holdings, transactions; Plaid handles the underlying credentials and shares only authorized data tokens with us.
- **Manually entered custom assets** — non-brokerage holdings (real estate, vehicles, precious metals, crypto wallets, collectibles, private investments, etc.) that you choose to track. You enter the value and asset type yourself; we never independently appraise.

1.3 Usage data (collected automatically)

- Browser type and version (User-Agent string)
- IP address (used by Vercel for rate limiting and abuse prevention; not used for behavioral tracking)

- Pages visited within the app (used only for error diagnostics; no third-party analytics like Google Analytics, Mixpanel, or Segment is installed)
- Theme + currency preferences (stored locally in your browser)

1.4 What we do NOT collect

- We do **not** store your broker passwords, banking PINs, or social insurance number (SIN/SSN).
- We do **not** store the raw broker file you upload — only the parsed positions/transactions are saved.
- We do **not** install third-party tracking pixels or behavioral analytics.
- We do **not** sell or share your data with advertisers, data brokers, or any commercial third party.

2. How we use your information

We process your data only for the purposes you would reasonably expect from a personal portfolio tracker:

Purpose	Legal basis (GDPR)
Display your portfolio, holdings, and analytics	Contract performance
Send you service emails (password reset, security notices)	Contract performance + legitimate interest
Send you optional marketing/feature emails (only if opted in)	Consent
Provide live price quotes via Finnhub (using only public ticker symbols, no personal data)	Contract performance
Detect and prevent abuse, fraud, or unauthorized access	Legitimate interest
Comply with legal obligations (court orders, tax authorities)	Legal obligation

We do **not** make automated decisions that produce legal effects on you (no algorithmic credit scoring, no automated trading, no behavioral profiling).

3. Where your data is stored

Data	Storage location	Provider
Account data, holdings, transactions, profile	Supabase Postgres (AWS us-east-2 / Ohio)	Supabase Inc. (SOC 2 Type II)

Data	Storage location	Provider
Profile photos	Supabase Storage (same region)	Supabase Inc.
Web app code + serverless functions	Vercel (global edge, primary US East)	Vercel Inc. (SOC 2 Type II)
Internal email	Microsoft 365 (Canada region)	Microsoft Corporation
Plaid connection tokens	Supabase + Plaid's own servers	Plaid Inc. (SOC 2 Type II)

All data is encrypted **at rest** (AES-256 via AWS KMS, managed by Supabase) and **in transit** (TLS 1.2+ minimum, TLS 1.3 preferred).

4. How long we keep your data

Data	Retention
Active account data	While your account is active
Account data after deletion request	Hard-deleted within 24 hours from <code>holdings</code> , <code>realized_positions</code> , <code>transactions</code> , <code>import_batches</code> , <code>watchlist</code> , <code>accounts</code> , <code>institutions</code> , <code>user_profiles</code> , <code>plaid_items</code> , the Supabase Storage <code>avatars</code> bucket, and the <code>auth.users</code> authentication record. After deletion the user cannot sign back in.
Plaid access tokens after deletion	Revoked via Plaid's <code>/item/remove</code> API automatically and immediately as part of the full-account-delete cascade (the <code>/api/account/delete-all</code> serverless function loops over every <code>plaid_items</code> row and revokes each before deleting the database row). Tokens are also revoked when the user explicitly disconnects an individual Item from Settings without deleting the account.
Operational audit signals (Supabase Auth audit log, Postgres logs, Vercel function logs)	Per Supabase tier policy (currently 7 days on Free; longer on Pro)
Backup copies (Supabase automated daily backups, retention per Supabase tier)	Cycled out per Supabase backup rotation (currently 7 days on Free tier)

Data	Retention
Marketing email opt-in records (if applicable)	Until withdrawn + 30-day suppression list

See the companion document **DATA_RETENTION_POLICY.md** for the technical implementation.

5. Your rights

Regardless of jurisdiction, you have the right to:

- **Access** — request a copy of all data we hold about you ([Settings → Privacy & Data → Export your data](#) , or email privacy@unifolio.ca).
- **Rectify** — correct any inaccurate data ([Profile](#) page, or email).
- **Delete** — request permanent deletion of all your data ([Settings → Privacy & Data → Delete All Data](#)). Deletion is irreversible.
- **Port** — receive your data in a portable format (CSV / JSON, available via the in-app export tools).
- **Object** — opt out of any non-essential processing (e.g. optional emails) at any time.
- **Withdraw consent** — at any time, with no penalty.
- **Lodge a complaint** with the **Office of the Privacy Commissioner of Canada** (<https://www.priv.gc.ca>) or, if you're in the EU/UK, your local data protection authority.

We respond to all rights requests within **30 days** (PIPEDA standard) or **1 month** (GDPR standard), whichever applies.

6. Sharing your data

We share your data **only** with the service providers listed in §3, each of whom processes data solely to provide their service to us under their own SOC 2 / GDPR commitments.

We do **not** share data with:

- Advertisers or data brokers
- Other Unifolio users
- Researchers or third-party analytics
- Anyone else, unless legally compelled by Canadian or applicable foreign law

If we receive a legal demand for your data (warrant, subpoena, court order), we will:

1. Verify the demand's legal validity.
2. Notify you of the demand unless legally prohibited from doing so.

3. Provide only the minimum data required.

7. Cookies and local storage

Unifolio uses **first-party local storage and session cookies only**, for:

- Keeping you signed in (`sb-access-token` from Supabase Auth)
- Caching your theme, currency, and view preferences
- Caching company profile data and ETF metadata to minimize repeat API calls

We use **no third-party cookies** and **no advertising trackers**. You can clear all our local data by signing out and clearing your browser's site data for unifolio.ca.

8. Children

Unifolio is intended for users 18 and over. We do not knowingly collect data from children under 13 (under 16 for EU/UK users). If you believe a child has created an account, contact privacy@unifolio.ca and we will delete the account immediately.

9. International transfers

If you access Unifolio from outside Canada, your data may be transferred to and processed in Canada and the United States (where Supabase and Vercel host their infrastructure). Both jurisdictions are deemed adequate for EU/UK personal data transfers under the EU-US Data Privacy Framework and the UK Extension. Unifolio uses Standard Contractual Clauses with all sub-processors when required.

10. Security incidents

In the event of a personal data breach that poses a risk to your rights and freedoms, we will:

- Notify you within **72 hours** of confirming the breach (PIPEDA + GDPR standard).
- Notify the Office of the Privacy Commissioner of Canada and any other applicable regulator within the same window.
- Publish a public incident report on unifolio.ca/security/incidents.

For full incident-response procedures, see our **INFOSEC_POLICY.md**.

11. Changes to this policy

We will notify users of material changes to this policy at least **30 days in advance** by email and via an in-app banner. Non-material changes (typo fixes, clarifications) are noted in the version-control history of `docs/PRIVACY_POLICY.md` in our public repository.

12. How to contact us

Privacy questions, rights requests, or complaints:

- Email: **privacy@unifolio.ca**
- Response time: 5 business days for acknowledgement; 30 days for substantive response.
- Postal correspondence: available on request via the email above.

Security vulnerabilities or incidents:

- Email: **security@unifolio.ca**
-

This policy was last reviewed and adopted by Ahmed Al-Samak, CEO of Unifolio Inc., on 2026-05-13.